

EVARO

Security, Compliance & Production-Readiness Roadmap

Release-Hardening und sichere Weiterentwicklung - Stand 19.09.2026

Quellenbasis: vollständige Deep Research zu knrds/fitness-tracker + gemeldeter EVARO-Projektstand.

Wichtiger Status-Hinweis

Der aktuelle Projektstatus in diesem Dokument basiert auf den zuletzt gemeldeten Gemini-/Projekt-Reports und muss von Astra gegen den echten Repository-HEAD verifiziert werden. Ein Scaffold, Test-Harness oder Dokument gilt nicht als Production-Control, solange es nicht integriert und adversarial verifiziert wurde.

Rechtlicher Hinweis

Diese Roadmap strukturiert technische, organisatorische und Compliance-Aufgaben. Sie ersetzt keine individuelle Rechtsberatung. Rechtsgrundlagen, Art.-9-Einordnung, DPIA, Verbraucherrecht, Store-Erklärungen und finale Texte sollten vor öffentlichem Release professionell geprüft werden.

1. Executive Security Map

Die Deep Research identifiziert als zentrale Failure Modes insbesondere Cross-User-Zugriffe/IDOR, fehlerhafte RLS/Grants, Secret-Leaks, unsichere Sessions, Sync-Datenverlust, unvollständige Account-Löschung, AI-Kosten-/Safety-Risiken, clientseitig manipulierbare Premium-Rechte, Health-/Privacy-Fehlklassifikation, Supply-Chain-Risiken und fehlende Restore-/Monitoring-Fähigkeit.

ID	Security-Domain	Priorität	aktueller gemeldeter Stand	Lead
S0	Repository Truth & Threat Model	P0	PARTIAL / verify	ASTRA
S1	Secrets, Supply Chain & CI Foundation	P0	PARTIAL	ASTRA + GEMINI
S2	Authentication & Secure Session Storage	P0	PREPARED	ASTRA
S3	Authorization, RLS & Multi-Tenant Isolation	P0	PREPARED	ASTRA
S4	Sync & Data Integrity	P0	PARTIAL	ASTRA
S5	Account Lifecycle, Privacy & Health Data	P0	PREPARED	ASTRA + USER/LEGAL
S6	AI Coach Security, Safety & Cost Controls	P0	PARTIAL	ASTRA
S7	Subscription / Premium Integrity	P1	PREPARED	ASTRA + USER
S8	Infrastructure, Backup, Monitoring & Incident Response	P0/P1	PARTIAL	ASTRA + USER
S9	AppSec Automation & Security Testing	P0/P1	PARTIAL	ASTRA + GEMINI
S10	Store, Legal, Accessibility & Release Compliance	P0/P1	PARTIAL	USER/LEGAL + ASTRA
S11	Physical Device & Pre-Launch Red Team	P0	OPEN	ASTRA + USER
S12	Post-Launch Security Operations	P2+	FUTURE	ASTRA + GEMINI + USER

Release-Leitsatz

SECURE-BY-DESIGN

Data Integrity > Authorization/Security > Privacy > Subscription Integrity > Crash Stability > Performance > UX > neue Features. Feature-Expansion bleibt eingefroren, bis die P0-Gates grün sind.

Gemeldeter EVARO-Ausgangspunkt

- Bereits vorbereitet/teilweise implementiert: SecureStore-Adapter und Migrationstests, RLS-Audit/Test-Harness, Account-Deletion-Client, lokaler Export, Entitlement-Abstraktion, AI-Safety/Request-Validation, privacy-safe Logger/Diagnostics, ErrorBoundary, Regression-/Performance-Tests und Store-/Device-Checklisten.
- ExerciseDB wurde entfernt; verbleibende Daten-/Asset-Provenienz muss technisch und lizenzseitig verifiziert bleiben.
- Kritisch noch zu beweisen/aktivieren: Secure Session Storage, echte RLS-/Grant-Isolation, Multi-Device-Sync/Data-Integrity, Cloud Account Deletion, Production-AI-Backend, serverseitige Pro-Entitlements/Billing, Restore/Monitoring/Incident Operations, echte Device-QA.
- Der Stand muss von Astra am echten aktuellen Git-HEAD neu gemessen werden; frühere Testzahlen oder Reports sind keine Quelle der Wahrheit.

2. Security Feature Map - was EVARO vor Release wirklich braucht

S0 - Repository Truth & Threat Model

Feld	Inhalt
Priorität	P0
Lead	ASTRA
Gemeldeter Stand	PARTIAL / verify
Ziel	Kanonischen Git-Stand, Datenflüsse, Trust Boundaries, Secrets, Provider, Tabellen, Endpunkte und tatsächliche Roadmap verifizieren. STRIDE/LINDDUN auf den Ist-Code anwenden.
Abnahmekriterium / Gate	Kein Security-Finding darf auf Annahmen basieren; aktuelle Baseline und Attack-Surface-Matrix dokumentiert.

S1 - Secrets, Supply Chain & CI Foundation

Feld	Inhalt
Priorität	P0
Lead	ASTRA + GEMINI
Gemeldeter Stand	PARTIAL
Ziel	Git-History-/Bundle-Secret-Scan, Dependency-/Lizenzscan, Actions-Permissions, SHA-Pinning, SAST/SCA/Secret-Gates, reproduzierbare Builds.
Abnahmekriterium / Gate	0 privilegierte Secrets im Repo/Bundle; PR-Gates blockieren neue Leaks/Criticals.

S2 - Authentication & Secure Session Storage

Feld	Inhalt
Priorität	P0
Lead	ASTRA
Gemeldeter Stand	PREPARED
Ziel	Geminis SecureStore-/Dual-Read-Scaffold verifizieren und kontrolliert aktivieren; Login/Logout/Refresh/Reset/OAuth/Account-Switch adversarial testen.
Abnahmekriterium / Gate	Tokens nur sicher gespeichert; Logout/Reset revoked korrekt; kein Data Loss/ungeplanter Logout bei Migration.

Kritische Tests:

- Dual-read / corrupt legacy / write-failure / concurrent startup
- Logout/Reset/Account-Switch
- kein Token-Leak in Logs/Diagnostics

S3 - Authorization, RLS & Multi-Tenant Isolation

Feld	Inhalt
Priorität	P0
Lead	ASTRA
Gemeldeter Stand	PREPARED
Ziel	Alle user-owned Tabellen/RPCs/Views/Grants inventarisieren. User A vs User B vs anon für SELECT/INSERT/UPDATE/DELETE testen. Deny-by-default.
Abnahmekriterium / Gate	Cross-user tests vollständig grün; kein ownerId/userId aus Client als Autorität; RLS + Grants verifiziert.

Kritische Tests:

- User A vs User B vs anonymous

- SELECT/INSERT/UPDATE/DELETE
- RLS + Grants + Views + RPCs + SECURITY DEFINER

S4 - Sync & Data Integrity

Feld	Inhalt
Priorität	P0
Lead	ASTRA
Gemeldeter Stand	PARTIAL
Ziel	Offline Queue, Idempotenz, Retries, Deletes, Account Switch, Multi-Device-Konflikte, Revision/Tombstone-Strategie nur wo nötig.
Abnahmekriterium / Gate	Kein Workout/Measurement/Plan-Verlust bei Retry, Offline, Logout, Multi-Device; Tests für Replay/Conflict/Delete.

Kritische Tests:

- Retry/Replays
- offline -> reconnect
- delete conflicts
- multi-device edits
- account switch scope isolation

S5 - Account Lifecycle, Privacy & Health Data

Feld	Inhalt
Priorität	P0
Lead	ASTRA + USER/LEGAL
Gemeldeter Stand	PREPARED
Ziel	Echte Cloud-Account-Löschung, Export, Retention, Provider-Löschung, Backup-Retention, Data Map, Art. 6/9, DPIA-Screening, Privacy by Default.
Abnahmekriterium / Gate	Cloud-Erfolg vor lokalem Wipe; Export/Löschung E2E getestet; High-Sensitivity-Daten nicht in Telemetry.

Kritische Tests:

- Cloud failure preserves local data
- confirmed remote success before local wipe
- Export-Scope ehrlich
- Storage/Provider/Backup-Retention berücksichtigt

S6 - AI Coach Security, Safety & Cost Controls

Feld	Inhalt
Priorität	P0
Lead	ASTRA
Gemeldeter Stand	PARTIAL
Ziel	Backend-only Provider-Key, Auth, Pro-Entitlement, distributed rate limit, budgets, payload limits, bilingual Safety, medical boundary, privacy minimization, kill switch.
Abnahmekriterium / Gate	Kein unauth. Kostenpfad; keine Secrets im Client; Safety DE/EN; AI niemals Security Principal; Budget-/Abuse-Tests grün.

Kritische Tests:

- unauthenticated/free-user/over-quota
- prompt injection/system prompt leakage
- DE/EN emergency responses

- parallel cost-abuse/provider timeout

S7 - Subscription / Premium Integrity

Feld	Inhalt
Priorität	P1
Lead	ASTRA + USER
Gemeldeter Stand	PREPARED
Ziel	RevenueCat/StoreKit/Play Billing, serverseitige Entitlements, Webhook-Signatur, Idempotenz, Refund/Cancellation, Beta-Bypass entfernen/scopen.
Abnahmekriterium / Gate	Client-Manipulation schaltet Pro nicht frei; restore/purchase/revoke auf echten Store-Sandboxes getestet.

Kritische Tests:

- patched client cannot unlock Pro
- webhook replay/idempotency
- restore/refund/cancel in store sandbox

S8 - Infrastructure, Backup, Monitoring & Incident Response

Feld	Inhalt
Priorität	P0/P1
Lead	ASTRA + USER
Gemeldeter Stand	PARTIAL
Ziel	Prod/Staging-Trennung, IAM/MFA, Secret Manager, Backups, Restore Drill, Alerts für Auth/5xx/AI-Kosten/Webhooks, Incident Runbooks.
Abnahmekriterium / Gate	Restore erfolgreich; Alerts aktiv; Incident Owner benannt; kein Production-Zugriff mit unnötigen Rechten.

S9 - AppSec Automation & Security Testing

Feld	Inhalt
Priorität	P0/P1
Lead	ASTRA + GEMINI
Gemeldeter Stand	PARTIAL
Ziel	CodeQL/Semgrep, Gitleaks, pnpm/GHSA, Lizenzscan, RLS Security Tests, Migration Tests, ZAP/Burp-Staging-Smoketests.
Abnahmekriterium / Gate	Security-Gates laufen in PR; Regressionstests für jedes behobene Finding.

S10 - Store, Legal, Accessibility & Release Compliance

Feld	Inhalt
Priorität	P0/P1
Lead	USER/LEGAL + ASTRA
Gemeldeter Stand	PARTIAL
Ziel	Datenschutz/Impressum/Terms/AI-Transparenz, Apple/Google Health/Data Safety, Account Deletion, Accessibility, Asset-Provenienz/Lizenzen.
Abnahmekriterium / Gate	Pflichtseiten/Store-Formulare stimmen mit echten Datenflüssen überein; keine ungeklärten ausgelieferten Asset-Rechte.

S11 - Physical Device & Pre-Launch Red Team

Feld	Inhalt
------	--------

Priorität	P0
Lead	ASTRA + USER
Gemeldeter Stand	OPEN
Ziel	iOS/Android reale Geräte, Process Death, Gestures, Haptics, Audio, Deep Links, App Update, Session Migration, Payment Sandbox; unabhängiger AuthZ/Business-Logic-Red-Team-Pass.
Abnahmekriterium / Gate	Release Gate vollständig PASS; 0 Critical, 0 ungeklärte High; echte Device-Smoke-Tests bestanden.

S12 - Post-Launch Security Operations

Feld	Inhalt
Priorität	P2+
Lead	ASTRA + GEMINI + USER
Gemeldeter Stand	FUTURE
Ziel	Security Alerts, Cost/Usage Monitoring, monatliche Dependency/IAM Reviews, quartalsweise Restore/Threat Model/DAST, halbjährliche Incident Exercises, jährliche Legal/Security Reviews.
Abnahmekriterium / Gate	Wiederkehrende Kontrollen besitzen Owner, Termin und dokumentierte Ergebnisse.

3. Priorisierte Umsetzung - 4 Release-Waves

Wave	Security-Bereiche	Ergebnis	Release-Regel
Wave A - Fundament sichern	S0, S1, S2, S3	Repo-Wahrheit, Secrets/Supply Chain, Secure Sessions, Authorization/RLS	Release sofort BLOCKED, wenn hier Critical/High offen bleibt.
Wave B - Daten & Privatsphäre	S4, S5	Sync/Data Integrity, Account Lifecycle, Health-/Privacy Architecture	Kein Public Beta mit unbewiesenem Cross-User-/Data-Loss-Risiko.
Wave C - Monetarisierbare AI	S6, S7	Production AI + Cost Controls + Billing/Entitlements	Kein kostenpflichtiger Launch bei client-authoritativem Premium oder AI ohne Budgetkontrollen.
Wave D - Betriebsfähigkeit & Release	S8-S11	Backups/Monitoring/CI/Legal/Store/Device/Red Team	Release erst nach vollständigem Gate + realen Device- und Restore-Tests.

Empfohlene Agenten-Aufteilung

Bereich	Astra	Gemini	User/Legal
Auth/RLS/Sync/DB-Migration	Lead	Tests/Docs	Credentials/Prod-Freigabe
Account Delete/Privacy Tech	Lead	Tests/Docs	Legal Basis/Privacy Text
AI Backend/Safety/Cost	Lead	Safety/i18n Tests	Provider/Contracts
Billing	Lead	UI/Test Harness	Store/RevenueCat/Pricing
CI/AppSec Automation	Lead bei Security-Design	Implementierung/Docs	GitHub Settings falls nötig
UI/i18n/a11y/QA	Review	Lead	Device Testing
Legal/Store/Lizenzen	Technische Evidenz	Inventare	Finale Entscheidung/Review

Credits-/Token-effiziente Astra-Nutzung

- High für S0/S2/S3/S4/S5/S6/S7 Architekturentscheidungen und High/Critical Findings.
- Medium für klar spezifizierte Implementierung, Tests, CI-Pipeline und Dokumentationsupdates nach Architekturentscheid.
- Ultra nur punktuell, wenn High bei einem konkreten komplexen Migrations-/Sync-/Security-Problem keine belastbare Lösung findet.

- Gemini für UI/i18n/a11y, Regressionstests, Inventare, QA und risikoarme Fixes.

4. Harte Release Gates

EVARO ist RELEASE = FAIL, sobald mindestens einer der folgenden Punkte zutrifft:

- Offenes Critical Finding oder ungeklärtes High Finding.
- Privilegiertes Secret in Repository, Git-History, Client-Bundle, Build-Logs oder Crash-Logs.
- Cross-User Authorization/RLS nicht mit mindestens zwei Accounts negativ getestet.
- Account-Löschung nur lokal, unvollständig oder nicht E2E getestet.
- AI-Endpunkt ohne Auth, Quota/Rate-Limit oder Budget-/Kill-Switch-Kontrolle.
- Premium/Entitlement kann durch Client-State autoritativ manipuliert werden.
- Backup vorhanden, aber kein erfolgreicher Restore-Test.
- Datenschutzerklärung/Store-Disclosure widerspricht tatsächlichem Datenfluss.
- Art.-9/High-Sensitivity-Daten ohne dokumentierten Verarbeitungs-/Schutzansatz.
- Kritische Dependency-Schwachstelle ohne dokumentierte Mitigation.
- Ungeklärte kommerzielle Rechte an ausgelieferten Assets/Datasets.
- Physische iOS-/Android-Kernflows vor Release nicht getestet.

Release PASS erfordert

- 0 Critical Findings und 0 ungeklärte High Findings.
- Alle P0-Controls implementiert und verifiziert - nicht nur dokumentiert.
- Build reproduzierbar; Tests, Security Tests, Secret Scan und Dependency Gate grün.
- Cross-User AuthZ/RLS Matrix grün.
- Erfolgreicher Restore-Test dokumentiert.
- Monitoring/Alerts aktiv und Incident Owner benannt.
- Privacy/Legal Baseline und Store-Disclosures stimmen mit echten Datenflüssen überein.
- Account Delete/Export verifiziert.
- Echte iOS-/Android-Kern-Smoke-Tests bestanden.

High-Risk-Ausnahme

Ein bewusst akzeptiertes High Finding braucht: Finding, Impact, Exploitability, Mitigation, Owner und Ablaufdatum. Ohne diese sechs Felder bleibt das Gate FAIL.

5. Secure Development Lifecycle fuer EVARO

Bei jedem Commit

- Targeted Tests
- Lint/Typecheck
- Secret-Precheck
- keine sensiblen Logs/Fixtures

Bei jedem Pull Request

- Full Tests + Build
- SAST (CodeQL/Semgrep)
- Dependency Scan

- Secret Scan
- License Scan
- RLS/Migration Security Tests, falls betroffen
- Human Diff Review

Bei jedem Deployment

- Immutable/reproduzierbares Artifact
- Environment Validation
- Migration Preview
- Backup vorhanden
- Rollback-Pfad
- Security Smoke Test

Wiederkehrend

Rhythmus	Kontrolle
Wöchentlich	Security-/Dependency-Alerts, AI-/API-Kostenanomalien, Auth-/5xx-Anomalien
Monatlich	IAM/Cloud/GitHub-Berechtigungen, Dependencies, Vendor-/SDK-Änderungen, Logs
Quartalsweise	Restore-Test, Threat Model, DAST, Cross-User/AuthZ-Red-Team, Access Review
Halbjährlich	Incident Tabletop, Privacy-/Processor Review
Jährlich / Major Launch	Externer Security-/Privacy-/Legal-Review bzw. Pentest

6. Privacy, Health Data & Legal Engineering

Die Research empfiehlt, Körper-/Health-/AI-Daten technisch als High-Sensitivity zu behandeln, auch wenn die juristische Art.-9-Einordnung einzelner Felder kontextabhängig bleibt.

Datenklasse	EVARO-Beispiele	Technische Regel
Personal	E-Mail, Profil, Ziele	minimieren, Zugriff kontrollieren, Retention definieren
Sensitive	Workout History, Kraftwerte, Programme	owner-only, kein Cross-User-Leak, Export/Delete
High Sensitivity	Gewicht, KFA, Maße, Verletzungen, Progress-Fotos, AI-Coach	keine generische Telemetry, minimale Provider-Weitergabe, strenge Retention/Deletion
Secret	Tokens, Service Keys, AI Keys	niemals Client/Logs; Secret Manager + Rotation

Vor öffentlichem Release rechtlich/operativ klären

- Data Map pro Zweck: Daten, Zweck, Art.-6-Grundlage, Art.-9-Ausnahme soweit relevant, Empfänger, Retention, Widerruf/Löschung, Drittlandtransfer.
- DPIA-Screening bei Kombination aus sensiblen Körper-/Gesundheitsdaten, AI-Coaching, langfristigem Profiling und ggf. Minderjährigen.
- Privacy by Default: Profile/Fotos nicht automatisch öffentlich.
- AI Coach sichtbar als AI kennzeichnen; medizinische Diagnose-/Therapie-Positionierung vermeiden.
- Apple/Google: Account Deletion, Health/Data Safety/Privacy Labels gegen tatsächliche Implementierung prüfen.
- Impressum/Datenschutz/Terms/Support/OSS-Lizenzen/Subscription-Informationen bereitstellen.
- Externe Provider: DPA, Subprozessoren, Transfers, Retention und Trainings-/Data-Use-Bedingungen dokumentieren.

7. Threat Model - priorisierte Attack Surface

#	Angriffsfläche	Angreiferziel	Kontrolle	Test
1	Supabase/RLS/BOLA	Fremde Workouts/Body Data lesen	RLS+Grants+Ownership Tests	User A/B Negative Tests
2	Secrets im Client/Git	Service/AI Key extrahieren	Backend-only + Secret Scan + Rotation	Bundle + Git-History Scan
3	Sync/Replay	Daten duplizieren/überschreiben	Idempotenz + Conflict Policy	Replay/Offline/Multi-Device
4	AI Cost Abuse	LLM-Tokens massenhaft verbrauchen	Auth + distributed limit + budget	Parallel abuse test
5	Premium Manipulation	Client setzt Pro=true	serverseitiges Entitlement	patched client / forged payload
6	Account Delete Race	lokal gelöscht, Cloud bleibt	remote-confirm-first + idempotent delete	cloud fail / retry / double-submit
7	Logging/Telemetry	Health/Token Leak	redaction + allowlisted events	seeded sensitive-value tests
8	Supply Chain/CI	malicious package/action	lockfile, SCA, pinned Actions, minimal perms	workflow/dependency audit
9	OAuth/Deep Link	Token/redirect leak	PKCE/state/exact redirects	malicious redirect tests
10	Future Uploads	Progress-Fotos öffentlich/EXIF leak	private bucket + validation + EXIF strip	cross-user fetch + upload corpus

8. Security Definition of Done

- Implementation und Integration abgeschlossen.
- Relevante Unit-/Integration-/Security-Tests grün.
- Auth/AuthZ explizit geprüft.
- Inputs, Limits, Fehler- und Offline-Fälle geprüft.
- Rate-/DoS-/Kostenrisiko betrachtet.
- Logging/Telemetry auf sensible Daten geprüft.
- Privacy-/Retention-/Export-/Delete-Impact geprüft.
- Dependency-/Lizenz-Impact geprüft.
- Migrations-/Rollback-/Data-Loss-Impact geprüft.
- Security Regression für behobene Schwachstellen ergänzt.
- DE/EN vollständig und Accessibility betrachtet.
- Dokumentation/Status aktualisiert; Working Tree sauber.

9. 30-/60-/90-Tage-Plan

Zeitraum	Primärziel	Ergebnis
0-30 Tage	S0-S4	Repo-Wahrheit, Secrets/CI-Basis, Secure Sessions, RLS/AuthZ, Sync-Invarianten belastbar.
31-60 Tage	S5-S8	Account Lifecycle/Privacy, AI Production Security, Billing-Integrität, Backup/Monitoring.
61-90 Tage	S9-S11	CI/AppSec automatisiert, Store/Legal/A11y final, Device-QA, Red-Team, Release Gate.
Post-Launch	S12	Monitoring, Incident-, Restore-, Vendor-, Dependency- und Legal-Zyklus operationalisiert.

10. Immediate Next Actions for Astra

1. Git-/Branch-/Tag-/Remote-Stand verifizieren und Security-Branch erstellen.
2. EVARO_SECURITY_GUARDRAILS.md sowie kanonische Release-/Astra-Dokumente lesen.
3. Baseline: verify, build, coach-check, audit, Expo config; CI/Secrets/Dependencies inventarisieren.
4. S0 Security State Matrix erstellen und Geminis Scaffolds in VERIFIED/PARTIAL/PREPARED/MISSING einstufen.
5. S1 Quick Gate: Secret-/Supply-Chain-/CI-Risiken mit geringem Aufwand eliminieren.
6. S2 Secure Session Storage verifizieren und kontrolliert aktivieren.
7. S3 RLS/Grants/Ownership mit User A/User B/anon adversarial testen.
8. S4 Sync/Data-Integrity erst nach Ist-Code-Analyse gezielt härten.
9. Danach S5 Account Lifecycle/Privacy und S6 Production-AI.
10. Erst nach grünem P0: S7 Billing/Entitlements und vollständiger Release-Hardening-Pfad.

11. Referenzrahmen aus der Deep Research

- OWASP API Security Top 10 / Authorization: deny-by-default, every-request authorization, BOLA/IDOR vermeiden.
- OWASP GenAI/LLM Security: Prompt Injection, Sensitive Information Disclosure, Excessive Agency, Tool/Context Risks.
- NIST SSDF: Security als normaler Bestandteil des SDLC.
- DSGVO Art. 5/6/9/12-22/25/28/32/33-35/44 ff.; sensible Fitness-/Health-Daten kontextbezogen behandeln.
- EU AI Act: AI-Transparenz fuer interaktive Systeme seit 02.08.2026 relevant.
- Apple/Google Store Policies: Account Deletion, Health/Data Safety, Subscription-/Privacy-Anforderungen.
- Deep-Research-Fälle zu Vibe-Coding/Supabase unterstreichen: Auth vorhanden bedeutet nicht Autorisierung sicher; RLS muss adversarial getestet werden.